A3-PS012-TC103

PS-012: Authorised DNS Resolver Exposure Assessment

CanaryScope — proving resolver recursion with evidence, not guesses

Shreyashi

Team A3-PS012-TC103 | AIORI Hackathon 3 | October 2026

Problem Description

- Open recursive DNS resolvers answer anyone on the Internet, so attackers use them as reflectors: a tiny spoofed query becomes a large response aimed at the victim (DDoS amplification).
- Common checks trust one signal (the RA flag, or "any reply"). Forwarders, middleboxes and cached answers cause false positives; timeouts and SERVFAIL leave results "inconclusive".
- The assessment must itself be safe: authorised targets only, bounded rate, no spoofing, no stress testing.
- Results must be reproducible and scored against known ground truth.

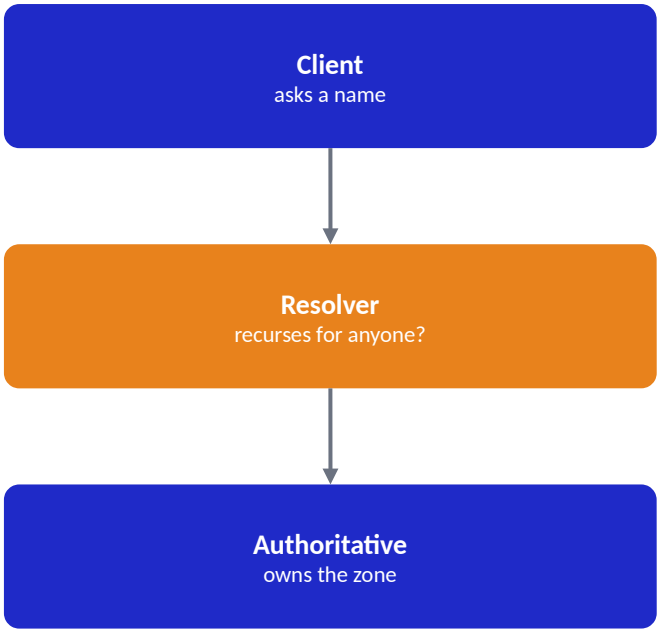
Our idea: CanaryScope

A lab-owned canary zone shows when a target resolver truly walked out to the Internet for a name only we know. That server-side proof cannot be faked by flags, caches or forwarders.

Result: fewer false positives, fewer "inconclusive" dead ends, and a safe, repeatable report.

Background

- Recursion: a resolver walks root → TLD → authoritative servers on behalf of clients [7]. Authoritative servers should only answer for their own zones.
- RFC 5358 (BCP 140) says recursion must be limited to intended clients; open recursion enables reflection attacks [1].
- Reflection needs spoofed source IPs, so ingress filtering (BCP 38) helps, but misconfigured resolvers remain a standing risk [8].
- Today: forgotten home-router and IoT forwarders, cloud VMs with default configs, and cheap attack-for-hire services keep this threat current.



Open resolver = step 2 answers every client

Literature & RFC Review

Source	Key insight	How we use it
RFC 5358 / BCP 140 [1]	Restrict recursion to intended clients; open recursion enables reflection	Defines our pass/fail baseline
Rossow, NDSS 2014 [2]	Quantifies DNS and other protocol amplification	Explains the risk; we never replay floods
Kührer et al., USENIX Sec. 2014 [3]	Internet-wide scans of open resolvers and amplifiers	Signal ideas; we stay lab-scoped, no Internet scans
Schomp et al., IMC 2013 [4]	Forwarders and recursors behave differently; flags mislead	Motivates canary proof of real recursion
RFC 6891 [5], RFC 7766 [6]	EDNS(0) and DNS over TCP	Retry paths that cut inconclusive results

Gap we fill: prior work focuses on Internet-scale measurement; we contribute a safe, lab-scoped, evidence-backed classifier scored against ground truth.

Proposed Solution: CanaryScope

1 Scope Guard: signed allow-list, max 20 IPs; anything else is refused

2 Baseline: in-zone query (RD=0) must return AA=1, proving the server is alive

3 Canary probe: RD=1 for a unique nonce label in our canary zone (TTL 0)

4 Evidence: flags and rcode, plus whether our canary server logged the nonce

5 Classify and compare with seeded ground truth; retry, TCP fallback, 3-probe vote

```
for t in scope.targets:      # <=20, allow-listed
  limiter.acquire(t)         # token bucket
  base = query(t, zone, RD=0)
  n = nonce(seed, t)
  r = query(t, n+".canary.lab", RD=1)
  hit = canary_log.seen(n)   # egress IP kept
  if hit:            label = RECURSIVE
  elif r.rcode==REFUSED: label = REFUSED
  elif base.AA and not r.RA and not hit:
                     label = AUTH_ONLY
  else:  retry(t) or label = INCONCLUSIVE
```

Canary hit = recursion proven, even when the reply is SERVFAIL.

Optimization Proposed

Aspect	Naive checker (before)	CanaryScope (after)
Evidence	RA flag or any reply	RA/rcode plus canary hit at our authoritative server
False positives	Forwarders and cached answers counted as recursive	Unique nonce, TTL 0; egress IP separates forwarders
Inconclusive	Timeouts and SERVFAIL left unresolved	Backoff retries, TCP fallback, 3-probe majority vote
Rate control	Fixed sleep between queries	Per-target token bucket, global cap, jitter, kill-switch
Safety	Any IP can be probed	Allow-list guard; no raw sockets, no spoofing
Reproducibility	Ad hoc runs	Seeded nonces, run manifest with hash, JSON + pcap evidence

Solution Architecture & Design

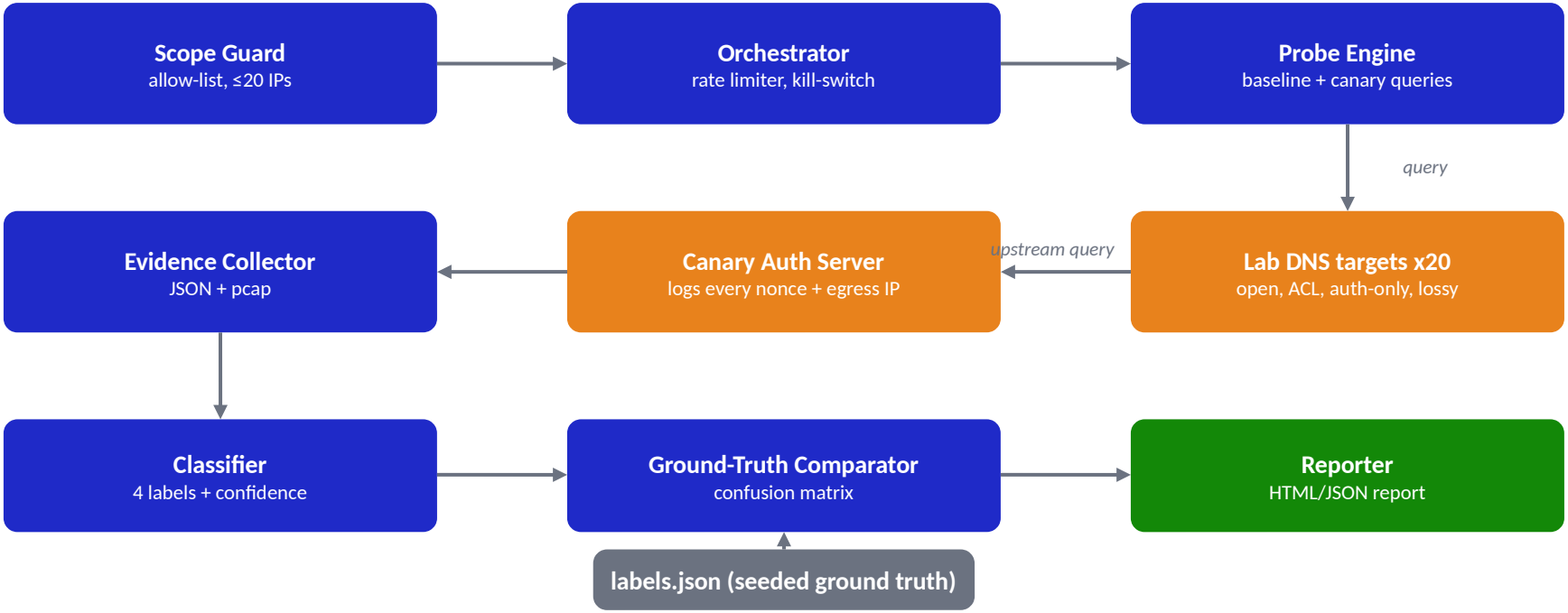


Figure: System architecture (lab-only, authorised targets)

Data Flow Diagram

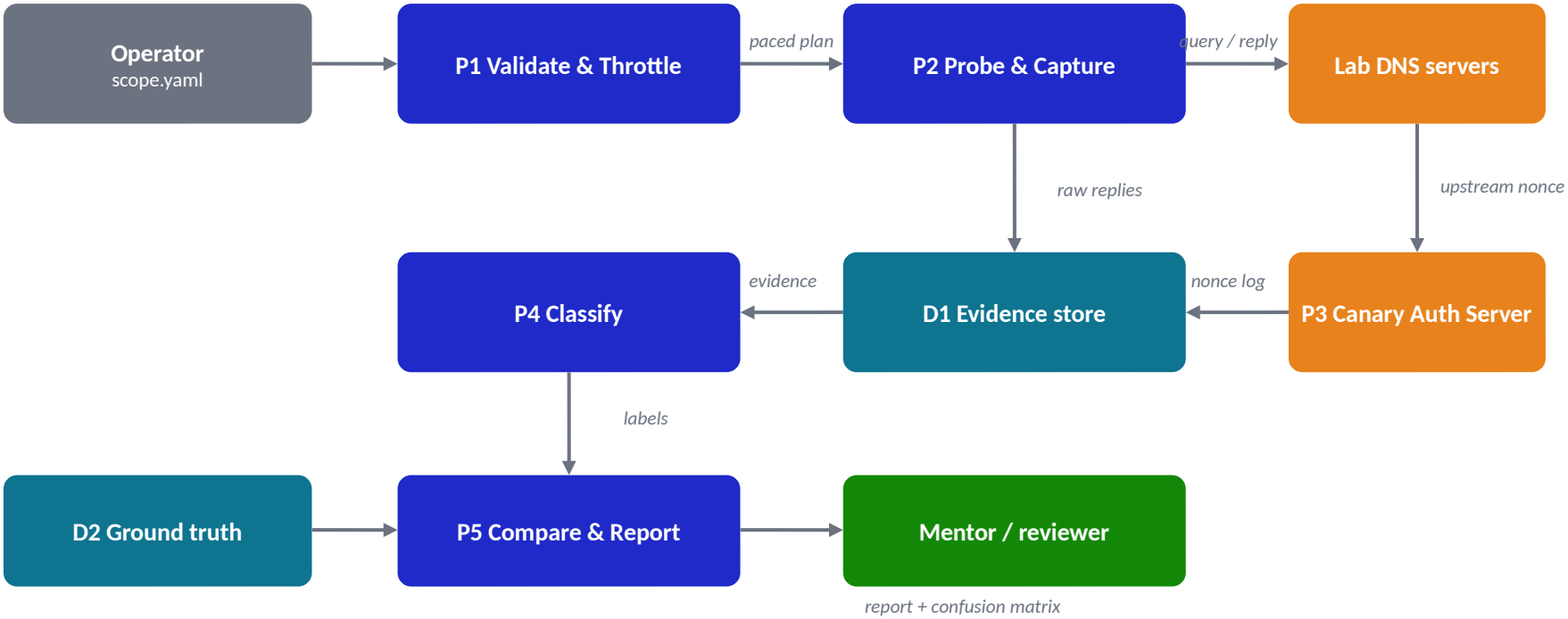


Figure: Data Flow Diagram (DFD)

Deployment Timeline

1 Lab & ground truth	2 Probe & canary	3 Classifier & rate control	4 Evaluate & report	5 Repo, PDF & demo
Docker lab of 20 BIND/Unbound/Knot servers: open, ACL-refused, auth-only, lossy; labels.json	dnspython probe engine, canary zone and auth server, nonce logging	Decision engine, retries, TCP fallback, token bucket, kill-switch	Confusion matrix, false/inconclusive analysis, HTML/JSON report	Private repo hand-off, PDF in prescribed structure, live demo + pseudocode

Methodology: 5 gated phases; every gate is an automated run against the seeded ground truth.

Targets: ≥95% agreement with ground truth, <5% inconclusive after retries, 0 packets outside scope, rate cap never exceeded.

Bibliography

[1] J. Damas, F. Neves. "Preventing Use of Recursive Nameservers in Reflector Attacks." RFC 5358 (BCP 140), 2008.

[2] C. Rossow. "Amplification Hell: Revisiting Network Protocols for DDoS Abuse." NDSS, 2014.

[3] M. Kührer, T. Hupperich, C. Rossow, T. Holz. "Exit from Hell? Reducing the Impact of Amplification DDoS Attacks." USENIX Security, 2014.

[4] K. Schomp, T. Callahan, M. Rabinovich, M. Allman. "On Measuring the Client-Side DNS Infrastructure." ACM IMC, 2013.

[5] J. Damas, M. Graff, P. Vixie. "Extension Mechanisms for DNS (EDNS(0))." RFC 6891, 2013.

[6] J. Dickinson et al. "DNS Transport over TCP - Implementation Requirements." RFC 7766, 2016.

[7] P. Mockapetris. "Domain Names - Concepts and Facilities." RFC 1034, 1987.

[8] P. Ferguson, D. Senie. "Network Ingress Filtering." RFC 2827 (BCP 38), 2000.

Thank You for Your Attention!

Prove recursion. Respect the network. Reproduce the result.

Shreyashi | Team A3-PS012-TC103 | AIORI Hackathon 3